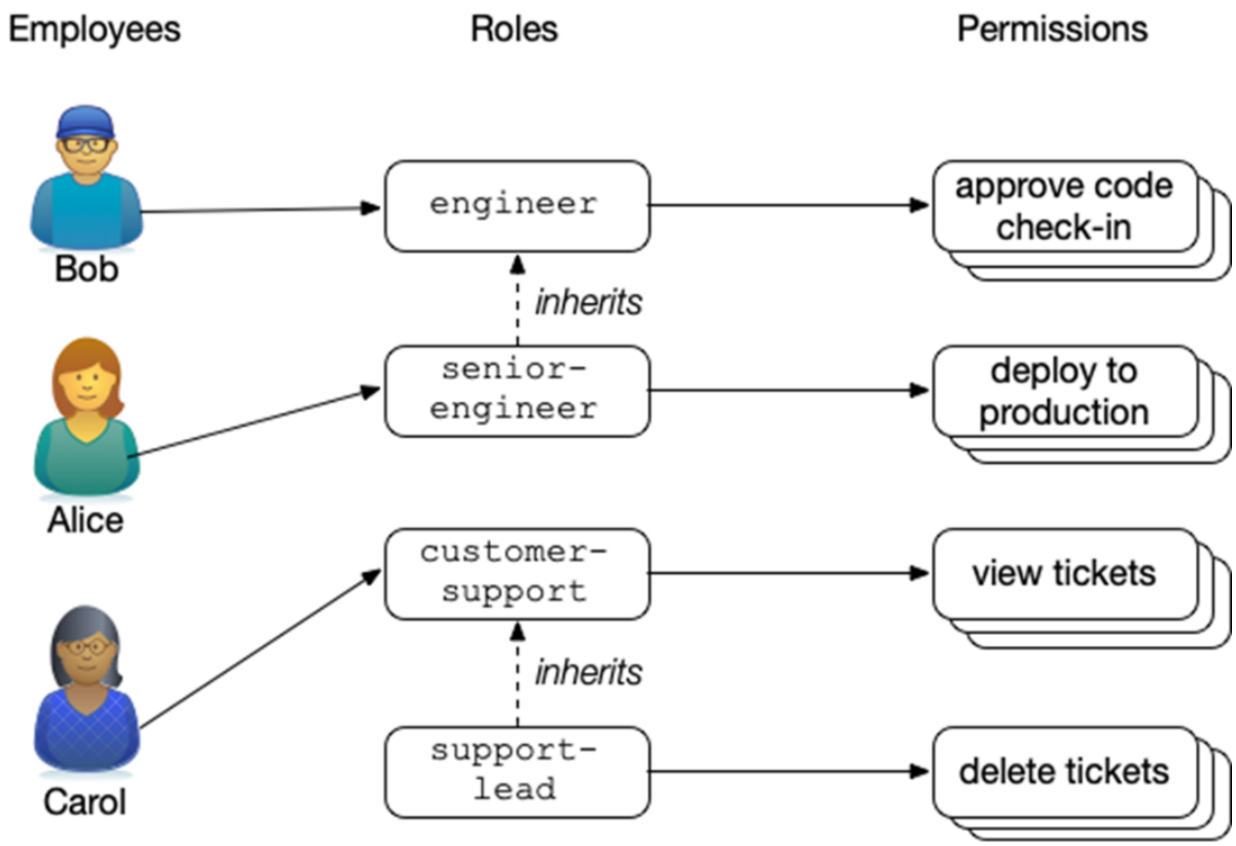


Figure 5.2 Users are assigned to roles like `engineer`, `senior-engineer`, or `support-lead`, which define what permissions they receive. Some roles inherit from others, allowing access to be layered and managed through organizational structure.

RBAC didn’t eliminate all complexity, but it created a layer of abstraction and consistency that facilitated the company's growth. It also provided auditors with something they had never had before: a clear, centralized picture of who could do what and why.

As shown in figure 5.2, RBAC introduces a level of indirection that makes authorization easier to understand and manage. By assigning permissions to roles instead of individual users, organizations can centralize access logic and align it with their internal structure. Role hierarchies further reduce duplication and facilitate the expression of progressive levels of responsibility. Though RBAC does not eliminate complexity, it offers a scalable foundation, especially when linked to identity lifecycle events such as hiring, promotions, or role changes.

In Access Control Lists (ACLs), permissions are attached directly to the resource, listing the specific principals allowed to perform certain actions. In